

ABC Healthcare Services

DATA CLASSIFICATION POLICY

Information Security Governance Program

Field	Details
Document ID	DCP-001
Version	1.0
Classification	Internal
Policy Owner	Information Security Manager
Approved By	Executive Management
Effective Date	June 1, 2026
Review Date	June 1, 2027

Document Revision History

Version	Date	Description	Author
1.0	June 1, 2026	Initial Release	Information Security Manager

1. PURPOSE

The purpose of this Data Classification Policy is to establish a consistent framework for classifying, handling, storing, transmitting, and disposing of organizational information based on its sensitivity and business value. Proper classification ensures that information receives an appropriate level of protection and reduces the risk of unauthorized disclosure, alteration, loss, or destruction.

Risk Statement

Failure to classify and protect information appropriately may result in data breaches, regulatory penalties, reputational damage, financial loss, and unauthorized access to sensitive information.

2. SCOPE

This policy applies to all employees, contractors, consultants, vendors, and third-party service providers who access, create, process, store, transmit, or dispose of organizational information. The policy applies to both electronic and physical information assets.

3. POLICY OBJECTIVES

- Protect sensitive information assets.
- Support regulatory and compliance obligations.
- Reduce information security risks.
- Promote consistent handling of data.
- Improve organizational accountability.

4. Data Classification Levels

4.1 Public Classification

Information approved for public release.

Examples

- Public website content
- Marketing brochures
- Press releases

Handling Requirements

- No special restrictions.
- Integrity must still be maintained.

4.2 Internal Classification

Information intended for internal business use only.

Examples

- Internal procedures
- Employee directories
- Organizational announcements

Handling Requirements

- Access restricted to authorized personnel.
- Storage on approved systems.

4.3 Confidential Classification

Sensitive business information requiring additional protection.

Examples

- Employee records and Contracts
- Customer information
- Financial documents

Handling Requirements

- Encryption is required during transmission.
- Access is based on business needs.

4.4 Restricted Classification

Highly sensitive information requires the highest level of protection.

Examples

- Medical records
- Regulatory investigations
- Security credentials
- Strategic business plans
- Security incident reports

Handling Requirements

- Encryption is required.
- MFA is required.
- Strict access controls.
- Senior management authorization where necessary.

5. Data Owners and Responsibilities

Role	Responsibility
Information Owner	Determine classification
Information Security Manager	Oversight and compliance
Department Managers	Enforce requirements
Employees	Protect information
IT Team	Implement technical controls

6. Data Handling Requirements

Classification	Encryption	Access Control	Sharing Restrictions
Public	Optional	Minimal Controls	Public Sharing Allowed
Internal	Recommended	Authorized Users Only	Internal Use Only
Confidential	Required	Restricted Access	Approved Personnel Only
Restricted	Mandatory	Strict Controls & MFA	Highly Restricted

7. Data Storage Requirements

Public Information

May be stored on approved organizational systems.

Internal Information

Stored on approved business systems with standard access controls.

Confidential Information

Must be stored on secured systems with encryption and access controls.

Restricted Information

Must be stored only on approved systems with advanced security controls, logging, monitoring, and encryption.

8. Data Transmission Requirements

All Confidential and Restricted information must:

- Be encrypted during transmission.
- Use approved communication channels.
- Be shared only with authorized recipients.
- Be protected against interception and modification.

9. Data Retention Requirements

Classification	Retention Period
Public	As required
Internal	3 Years
Confidential	7 Years
Restricted	Based on legal requirements

10. Data Disposal Requirements

Information shall be securely disposed of when no longer required.

Electronic Records

- Secure deletion
- Media sanitization
- Destruction of storage devices

Physical Records

- Cross-cut shredding
- Secure destruction services

11. Compliance Monitoring

Key Performance Indicators (KPIs)

Metric	Target
Data Classification Compliance	100%
Encryption Compliance	100%
Access Reviews Completed	100%
Secure Disposal Compliance	100%
Employee Awareness Training	95%

Sample Dashboard

Control	Result
Encryption Compliance	99%
Data Classification Accuracy	97%
Access Reviews	100%
Disposal Compliance	100%

12. Policy Violations

Failure to comply with this policy may result in:

- Disciplinary action
- Access suspension
- Employment termination
- Legal consequences where applicable

13. Policy Exceptions

Any exception to this policy requires:

- Business justification
- Risk assessment
- Management approval
- Security approval
- Documented compensating controls

14. Conclusion

ABC Healthcare Services is committed to protecting information assets through effective data classification and handling practices. Proper classification ensures that organizational information receives an appropriate level of protection based on its sensitivity and business value. Compliance with this policy supports risk management objectives, enhances regulatory compliance, and strengthens the overall security posture of the organization.

15. References

ISO/IEC 27001:2022

NIST Cybersecurity Framework

CIS Controls

Privacy and Confidentiality Standards

Information Security Governance Framework

16. Document Control

Field	Value
Document Owner	Information Security Manager
Document ID	DCP-001
Version	1.0
Classification	Internal
Review Frequency	Annual
Next Review Date	June 1, 2027